

D487

# Secure Software Design

Armored Drill

8 concepts · 12 items · 4 transfer items

**What this is.** Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

**Source.** Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

# How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | _____  |                               |

# Items

1.

A team building a patient portal plans one security scan the week before launch. The portal uses a popular JavaScript framework. What is the best improvement?

- A.** Add security requirements up front, threat model the design, and test throughout development.
- B.** Switch to a different framework.
- C.** Run the scan twice before launch.
- D.** Leave security to QA at the end; it is always cheaper there.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

2.

In threat modeling for a pharmacy refill app, the team finds a user could deny submitting a refill because nothing ties the action to them. The app has 50,000 monthly users. Which STRIDE category and mitigation fit?

- A.** Tampering; add hashing.
- B.** Denial of service; add rate limits for the large user base.
- C.** Repudiation; keep secure audit logs tied to user identity and time.
- D.** Spoofing; add MFA.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

3. [TRANSFER — reversed stem / different variable]

Authorization checks on every request mainly counter which STRIDE threat?

- A.** Repudiation.
- B.** Elevation of privilege.
- C.** Spoofing.
- D.** Information disclosure.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

4.

A login API sits behind a web application firewall. The developer says input validation in the code is not needed because the WAF blocks bad input; the WAF was bought last year at a discount. What is the right response?

- A. Keep both; the WAF can be bypassed or misconfigured, so the code must validate too.
- B. Remove the WAF since the code validates.
- C. Agree; the WAF is always enough.
- D. Replace it with a more expensive WAF.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

5.

A search feature builds its SQL statement by joining user-typed text into the query string. The feature was added by a summer intern and is popular with users. What is the best fix?

- A. Block a short list of special characters.
- B. Use parameterized queries and validate input on the server.
- C. Add JavaScript validation in the browser.
- D. Remove the feature because an intern wrote it.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

6. [TRANSFER — reversed stem / different variable]

Why is client-side input validation alone not enough?

- A. It is enough as long as the site uses HTTPS.
- B. Users can bypass it, so the server must validate too.
- C. Server validation is optional because it is slower.
- D. Client-side validation is more secure because it runs first.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

7.

A team wants to find known-vulnerable versions of open-source libraries listed in its build manifest. The repository holds 400,000 lines of code. Which tool fits?

- A. Software composition analysis (SCA).
- B. Static analysis (SAST).
- C. Dynamic testing (DAST).
- D. A manual review of all 400,000 lines.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

**8.** [TRANSFER — reversed stem / different variable]

A tool tests a running web app from the outside by sending requests and watching responses, with no access to source code. Which type is it?

- A.** Peer code review
- B.** SAST
- C.** SCA
- D.** DAST

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

**9.**

When the authorization service times out, the app lets the request through so users are not blocked. The authorization service runs in a separate region. Which principle applies, and what is the fix?

- A.** Retry forever until the service answers.
- B.** Failing open is fine because it helps users.
- C.** Move the service into the same region.
- D.** Fail secure: deny the request when authorization cannot be confirmed.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

**10.** [TRANSFER — reversed stem / different variable]

A new app ships with every feature and the admin console turned on and a default admin password. Which principle is violated?

- A.** None; only admins know the default password.
- B.** Defense in depth.
- C.** Fail secure.
- D.** Secure by default.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

**11.**

A company is buying a third-party HR application; the vendor has a slick demo and 200 clients. What should the purchase process require?

- A.** Rely on the demo and client list.
- B.** Nothing; security testing only applies to code we write.
- C.** Security requirements in the contract, a vendor security assessment, an SBOM, and patch commitments.
- D.** Compare price and features now and review security after rollout.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

**12.**

An Agile team releases 15 times a week, but a separate team reviews security once a quarter. The team's scrum master is certified. What is the best adaptation?

- A.** Skip security to keep up speed.
- B.** Rely on the scrum master's certification.
- C.** Automate SAST, SCA, and secret scanning in the pipeline and add security to the definition of done.
- D.** Cut releases to once a quarter.

| Target word | The one fact that decides | Answer | [ ] sure [ ] unsure [ ] guess |
|-------------|---------------------------|--------|-------------------------------|
| _____       | _____                     | ___    |                               |

# STOP

Answers and dissection follow. Finish every item and every strip first.

# Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

## 1. Answer A Concept 1

A team building a patient portal plans one security scan the week before launch. ~~The portal uses a popular JavaScript framework.~~ What is the best improvement?

**Target word:** SDLC-wide security **Decides:** Security appears only at the end.

|   |                   |                                                      |
|---|-------------------|------------------------------------------------------|
| A | <b>Correct</b>    | Finds design flaws early when they cost less to fix. |
| B | Camouflage        | Framework choice is not the process gap.             |
| C | Adjacent category | Still late and still misses design flaws.            |
| D | Absolute language | Late fixes cost more.                                |

## 2. Answer C Concept 2

In threat modeling for a pharmacy refill app, the team finds a user could deny submitting a refill because nothing ties the action to them. ~~The app has 50,000 monthly users.~~ Which STRIDE category and mitigation fit?

**Target word:** category and mitigation **Decides:** A user can deny an action.

|   |                   |                                                   |
|---|-------------------|---------------------------------------------------|
| A | Confusion set     | Tampering is changing data.                       |
| B | Camouflage        | Follows the user count, not the threat described. |
| C | <b>Correct</b>    | Logs provide proof of who did what.               |
| D | Adjacent category | Spoofing is posing as someone else.               |

## 3. Answer B Concept 2 · transfer

Authorization checks on every request counter which STRIDE threat?

**Target word:** reverse: control to threat **Decides:** Authorization limits what users can do.

|   |                    |                                                           |
|---|--------------------|-----------------------------------------------------------|
| A | Inverted operation | Countered by logging, not access checks.                  |
| B | <b>Correct</b>     | Stops users from acting beyond their rights.              |
| C | Confusion set      | Countered by authentication.                              |
| D | Adjacent category  | Mainly countered by encryption and access limits on data. |

## 4. Answer A Concept 3

A login API sits behind a web application firewall. The developer says input validation in the code is not needed because the WAF blocks bad input; ~~the WAF was bought last year at a discount.~~ What is the right response?

**Target word:** layered controls **Decides:** Removing one layer creates a single point of failure.

|   |                    |                                             |
|---|--------------------|---------------------------------------------|
| A | <b>Correct</b>     | Independent layers cover each other's gaps. |
| B | Inverted operation | Removes a layer the other way.              |
| C | Absolute language  | No single control is complete.              |
| D | Camouflage         | Price is not the issue.                     |



## 5. Answer B Concept 4

A search feature builds its SQL statement by joining user-typed text into the query string. ~~The feature was added by a summer intern and is popular with users.~~ What is the best fix?

**Target word:** fix for query injection risk **Decides:** User input is mixed into code.

|          |                   |                                                                     |
|----------|-------------------|---------------------------------------------------------------------|
| A        | Adjacent category | Block-lists miss variants; allow-lists and parameters are stronger. |
| <b>B</b> | <b>Correct</b>    | Keeps data separate from the SQL code.                              |
| C        | Dropped element   | Client checks can be skipped.                                       |
| D        | Camouflage        | Who wrote it is not the flaw.                                       |

## 6. Answer B Concept 4 · transfer

Why is client-side input validation alone not enough?

**Target word:** reason behind the rule **Decides:** The client is under the user's control.

|          |                    |                                                    |
|----------|--------------------|----------------------------------------------------|
| A        | Confusion set      | HTTPS protects transport, not input.               |
| <b>B</b> | <b>Correct</b>     | Requests can be sent without the browser's checks. |
| C        | Adjacent category  | Speed does not remove the need.                    |
| D        | Inverted operation | Running first does not make it trustworthy.        |

## 7. Answer A Concept 5

A team wants to find known-vulnerable versions of open-source libraries listed in its build manifest. ~~The repository holds 400,000 lines of code.~~ Which tool fits?

**Target word:** tool type **Decides:** The target is third-party components.

|          |                   |                                                            |
|----------|-------------------|------------------------------------------------------------|
| <b>A</b> | <b>Correct</b>    | SCA matches dependencies to known vulnerabilities.         |
| B        | Adjacent category | Focuses on the team's own source code.                     |
| C        | Confusion set     | Tests the running app, not the dependency list.            |
| D        | Camouflage        | Library versions are in the manifest, not the team's code. |

## 8. Answer D Concept 5 · transfer

A tool tests a running web app from the outside by sending requests and watching responses, with no access to source code. Which type is it?

**Target word:** reverse: behavior to tool **Decides:** Running app, outside view.

|          |                    |                                                 |
|----------|--------------------|-------------------------------------------------|
| A        | Confusion set      | Needs source code.                              |
| B        | Inverted operation | Reads source without running it.                |
| C        | Adjacent category  | Examines third-party components.                |
| <b>D</b> | <b>Correct</b>     | Dynamic testing exercises the live application. |

## 9. Answer D Concept 6

When the authorization service times out, the app lets the request through so users are not blocked. ~~The authorization service runs in a separate region.~~ Which principle applies, and what is the fix?

**Target word:** error-path behavior **Decides:** The app fails open.

|   |                    |                                                     |
|---|--------------------|-----------------------------------------------------|
| A | Adjacent category  | Hangs the app and still has no safe default.        |
| B | Inverted operation | Lets unauthorized requests through.                 |
| C | Camouflage         | Timeouts can still happen; the default is the flaw. |
| D | <b>Correct</b>     | Errors should not grant access.                     |

## 10. Answer D Concept 6 · transfer

A new app ships with every feature and the admin console turned on and a default admin password. Which principle is violated?

**Target word:** name the principle **Decides:** Insecure out-of-the-box settings.

|   |                   |                                                    |
|---|-------------------|----------------------------------------------------|
| A | Dropped element   | Default passwords are widely known.                |
| B | Confusion set     | About layering controls.                           |
| C | Adjacent category | About error handling.                              |
| D | <b>Correct</b>    | Ship minimal features and force a password change. |

## 11. Answer C Concept 7

A company is buying a third-party HR application; ~~the vendor has a slick demo and 200 clients.~~ What should the purchase process require?

**Target word:** secure acquisition **Decides:** Software is being bought, not built.

|   |                   |                                                |
|---|-------------------|------------------------------------------------|
| A | Camouflage        | Neither shows security quality.                |
| B | Absolute language | Bought software carries the same risks.        |
| C | <b>Correct</b>    | Holds the vendor to measurable security terms. |
| D | Dropped element   | Drops security from the decision.              |

## 12. Answer C Concept 8

An Agile team releases 15 times a week, but a separate team reviews security once a quarter. ~~The team's scrum master is certified.~~ What is the best adaptation?

**Target word:** fit security to fast delivery **Decides:** Release pace far outstrips review pace.

|   |                    |                                                           |
|---|--------------------|-----------------------------------------------------------|
| A | Dropped element    | Removes the control entirely.                             |
| B | Camouflage         | Process certification does not check code.                |
| C | <b>Correct</b>     | Security keeps pace with every release.                   |
| D | Inverted operation | Gives up the delivery model instead of adapting security. |

## Triage grid

Write each item number in the box it belongs to.

|                       | Right                                                 | Wrong                                                                                 |
|-----------------------|-------------------------------------------------------|---------------------------------------------------------------------------------------|
| <b>Sure</b>           | Owned.                                                | <b>Concept inversion — top priority.</b> A wrong mental model; it survives rewording. |
| <b>Unsure / guess</b> | Recognition, not mastery. Re-drill with the transfer. | Not learned yet.                                                                      |

## Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

| Trap               | What it does                                                 | In this drill | Your misses |
|--------------------|--------------------------------------------------------------|---------------|-------------|
| Dropped element    | Leaves out a required term or step.                          | 4             |             |
| Wrong stem number  | A figure copied from the prompt that is not the answer.      | 0             |             |
| Adjacent category  | The right idea in the wrong bucket.                          | 9             |             |
| Inverted operation | Direction flipped: add/subtract, cause/effect, higher/lower. | 6             |             |
| Absolute language  | Always, never, guarantee — where judgment applies.           | 3             |             |
| Confusion set      | Every option is real; the test is exact role-matching.       | 6             |             |
| Camouflage         | Answers a stem fact that was never the question.             | 8             |             |

# Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

| # | Concept                                | Rule                                                                                                                                                                                               | Trap                                                                  | Tell                                                  |
|---|----------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------|-------------------------------------------------------|
| 1 | <b>Security across the SDLC</b>        | Build security in from the start: security requirements, design review, secure coding, and testing in every phase; early fixes cost less.                                                          | One security scan just before launch.                                 | Security planned only at the end.                     |
| 2 | <b>Threat modeling with STRIDE</b>     | Spoofing → authentication; Tampering → integrity; Repudiation → audit logging; Information disclosure → confidentiality; Denial of service → availability; Elevation of privilege → authorization. | Mapping a threat to the wrong control.                                | A described threat and “which category / mitigation.” |
| 3 | <b>Defense in depth</b>                | Keep several independent layers so one failing control does not expose the application.                                                                                                            | Removing a layer because another exists.                              | “We don’t need X because Y handles it.”               |
| 4 | <b>Input handling</b>                  | Validate input on the server with allow-lists and use parameterized queries so data is never run as code.                                                                                          | Relying on client-side checks or blocking a few characters.           | User text joined into a query or command.             |
| 5 | <b>SAST, DAST, and SCA</b>             | SAST reads source without running it; DAST tests the running app from outside; SCA finds known-vulnerable third-party components.                                                                  | Using SAST to find library vulnerabilities, or DAST for source flaws. | Source code, a running app, or a dependency list.     |
| 6 | <b>Fail secure and secure defaults</b> | On error, deny access; ship with the most secure settings on and unneeded features off.                                                                                                            | Failing open to avoid blocking users.                                 | A timeout or error path, or out-of-the-box settings.  |
| 7 | <b>Secure acquisition</b>              | Bought software needs security requirements in the contract, a vendor assessment, component transparency (SBOM), and patch commitments.                                                            | Trusting demos, reputation, or client counts.                         | Buying a third-party application.                     |
| 8 | <b>Security in Agile and DevSecOps</b> | Automate security checks in the pipeline and include security in stories and the definition of done.                                                                                               | Slowing releases or skipping security to keep speed.                  | Frequent releases with occasional security reviews.   |

**Course scope (public description):** Secure Software Design focuses on the variety of elements needed to address and implement secure software acquisition and development throughout the software development life cycle (SDLC). The course addresses people, technology, tools, and processes to design and develop consistently secure applications from start to finish. Additionally, it underscores the importance and value of the Defense in Depth principle across the entire SDLC. The course also introduces techniques to adapt common security activities to modern software development practices such as Agile and DevSecOps.